



Weekly Cyber Threat Intelligence Report

Reporting window: 22 - 29 June 2026

Australia - APAC - Global - Emerging Threats - IOCs to Add

Prepared for: Jordan

Classification: TLP:CLEAR - cleared for public release

Source: CyberSec Vault automated intel sweep

PUBLIC

Executive Summary



This week was defined by **max-severity, internet-facing CVEs under active exploitation**, a surge of **public PoCs and CMS mass-exploitation**, and **software supply-chain compromises reaching into AI tooling and developer pipelines**. CISA KEV additions stacked up: Ubiquiti UniFi OS (CVE-2026-34908/09/10, CVSS 10, Mirai/Gafgyt), two Joomla extensions (JCE CVE-2026-48907 and SP Page Builder CVE-2026-48908, both CVSS 10, exploited), Ghost CMS SQLi (700+ sites hijacked for ClickFix), the Lantronix BRIDGE:BREAK OT 0-day (CVE-2025-67038), and Cisco Unified CM (CVE-2026-20230) and Catalyst SD-WAN (CVE-2026-20245, rogue 'troot' root account). A **critical libssh2 client-RCE (CVE-2026-55200)** and **NGINX RCEs** broaden the bundled-library blast radius, and a **FFmpeg 'PixelSmash' (CVE-2026-8461)** turns media files into RCE on Jellyfin. Supply chain was relentless - DPRK's Sapphire Sleet poisoned 141 @mastra npm packages, a Shai-Hulud/Miasma **'Phantom Gyp'** worm hit LeoPlatform npm, 15 malicious JetBrains AI plugins stole API keys (C2 live post-removal), and a Polymarket frontend inject drained ~\$3M. Law enforcement hit back via **Operation Endgame** (Amadey/StealC). Regionally, **ASD announced it will retire the Essential Eight**, and APAC saw the **Mastra/DPRK** attack and the **Tata Electronics** (India) leak of claimed Apple/Tesla IP. **Items are ordered verified-first, each with up to three independent references**; public PoCs and IOCs to add to blocklists/SIEM are called out in their own sections.

AUSTRALIA - SPECIFIC

Local orgs & policy

ASD to retire the Essential Eight within two years, replace with domain-specific 'Essentials' series

MEDIUM

VERIFIED

AU

ASD

Policy

Framework

On 24 June the Australian Signals Directorate confirmed it will retire the Essential Eight - the cornerstone of Australian government/industry hardening guidance since 2017 - replacing it with a broader, domain-specific 'Essentials' series spanning enterprise IT, cloud and OT (agentic AI under consideration). ASD cites the model's poor fit for cloud/shared-responsibility and the long-standing problem of shifting maturity-level goalposts. Expected to deprecate ~mid-2027 and fully retire ~mid-2028; consultation on the first chapter (Essentials for enterprise IT) is open via the ACSC Partner Portal until 12 July. Plan multi-year control-mapping and audit/contractual updates now.

Refs: itnews.com.au · australiancybersecuritymagazine.com.au · cyberdaily.au

Australian data-for-sale and bank-impersonation fraud claims (dark-web chatter)

MEDIUM

UNVERIFIED

AU

Fraud

DataLeak

Unverified

Lower-confidence local items from the week: a dark-web actor advertised an alleged 438,522-record Australian database for sale, and renewed ANZ/NAB-impersonation banking-scam activity was flagged targeting Australian customers. Both are unverified marketplace/social claims with no corroborating breach disclosure - logged for situational awareness; validate against your own fraud and exposure telemetry before acting.

Refs: x.com/DailyDarkWeb · x.com/JPMasters

APAC - SPECIFIC

Regional incidents & actors

Mastra AI npm supply-chain compromise - DPRK 'Sapphire Sleet' poisoned 141 @mastra packages

CRITICAL

VERIFIED

APAC

DPRK

npm

SupplyChain

Microsoft attributes (high confidence) the Mastra AI npm compromise to North Korea's Sapphire Sleet (BlueNoroff). After hijacking maintainer account 'ehindero', attackers published 141 packages in the @mastra scope in a ~45-minute burst, each pulling a malicious dependency 'easy-day-js' (a typosquat of dayjs). A postinstall hook ran an obfuscated dropper that disabled TLS verification, beacons to C2, and pulled a hidden second stage harvesting credentials, API keys, tokens and crypto data. Same actor was tied to the April 2026 Axios npm attack. Audit @mastra / easy-day-js usage, pin & hash-verify deps, rotate developer/CI/cloud secrets.

Refs: [microsoft.com](#) · [bleepingcomputer.com](#) · [securityweek.com](#)

Tata Electronics (India) - confirmed breach; World Leaks dumps ~204k files (Apple/Tesla IP)

HIGH

VERIFIED

APAC

India

Breach

SupplyChain

Tata Electronics (assembles ~a third of India's iPhones) confirmed a cyber incident affecting parts of its IT systems. Extortion group World Leaks listed the firm on its TOR portal and dumped ~204,341 files (~630GB), including documents bearing Apple proprietary markings (iPhone QC standards) and a Tesla 'TRADE SECRET' drawing referencing project Highland. Tata received a ransom demand; Apple is investigating. Operations reportedly unaffected. Partners/OEMs: treat shared docs/credentials as exposed, rotate shared secrets, and monitor World Leaks for follow-on dumps.

Refs: [cnbc.com](#) · [bleepingcomputer.com](#) · [techrepublic.com](#)

GLOBAL - ACTIVELY EXPLOITED & CRITICAL CVEs

[Patch now](#)**CVE-2026-34908/34909/34910 - Ubiquiti UniFi OS unauth root RCE chain (CVSS 10.0), exploited**

CRITICAL

VERIFIED

Appliance

RCE

Exploited

KEV

Three UniFi OS flaws - improper access control (34908), path traversal (34909) and command injection (34910), each CVSS 10.0 - chain to unauthenticated remote code execution with full root on internet-facing UniFi OS consoles. CISA added all three to KEV on 23 June (BOD 26-04, patch-by 26 June); active exploitation includes a Mirai/Gafgyt campaign. Patched in UniFi OS Server 5.0.8 (21 May). Patch immediately, pull management off the public internet, and hunt for new admin accounts/config changes.

PoC: Active exploitation in the wild (Mirai/Gafgyt botnet)Refs: bleepingcomputer.com · securityweek.com · cisa.gov**CVE-2026-48907 - Joomla Content Editor (JCE) improper access control -> PHP RCE (CVSS 10.0), exploited**

CRITICAL

VERIFIED

CMS

RCE

Exploited

KEV

Maximum-severity improper-access-control flaw in the widely deployed JCE (Widget Factory) editor lets unauthenticated attackers create editor profiles and upload/execute PHP. Affects JCE 1.0.0-2.9.99.4; fixed in 2.9.99.5 (3 Jun). On CISA KEV with automated in-the-wild exploitation and public exploit code; FCEB patch deadline 19 Jun. Update now, hunt for webshells and rogue Super User accounts.

PoC: Active exploitation (automated); public exploit codeRefs: thehackernews.com · bleepingcomputer.com · nvd.nist.gov**CVE-2026-48908 - SP Page Builder (Joomla) unauth file upload -> RCE (CVSS 10.0), exploited**

CRITICAL

VERIFIED

CMS

RCE

Exploited

The SP Page Builder asset.uploadCustomIcon task accepts a file with no login and no type check, letting any unauthenticated attacker drop a PHP webshell and run it. Affects all versions <= 6.6.1; fixed in 6.6.2 (adds auth + CSRF gating). ~194,793 sites estimated exposed; live attacks observed (POST to uploadCustomIcon -> GET planted PHP -> new Super User). IOC: hidden Super User accounts with @secure.local email domains indicate compromise.

PoC: Public - PoC (papageo75); live exploitation in logs - github.comRefs: censys.com · ionix.io · cvefeed.io**CVE-2026-26980 - Ghost CMS unauth blind SQLi (CVSS 9.4), exploited to hijack 700+ sites**

CRITICAL

VERIFIED

CMS

SQLi

Exploited

Unauthenticated blind SQL injection in the Ghost Content API (slug-filter-order.js concatenates attacker-controlled slug values into a raw SQL CASE/ORDER BY fragment). Affects Ghost 3.24.0-6.19.0; fixed in 6.19.1 (parameterised Knex). Allows blind read of any table - admin bcrypt hashes, session secrets, Admin API keys. Actively exploited to steal Admin API keys and inject ClickFix/fake-CAPTCHA JavaScript across 700+ sites. Public PoCs available; patch and rotate keys/secrets.

PoC: Public - PoC (vognik, dinosn); mass ClickFix campaign - github.comRefs: bleepingcomputer.com · thehackernews.com · sonicwall.com

CVE-2025-67038 - Lantronix EDS5000 'BRIDGE:BREAK' serial-to-IP root cmd injection (CVSS 9.8), exploited 0-day

CRITICAL

VERIFIED

OT

RCE

Exploited

KEV

Forescout reports CVE-2025-67038 (part of the BRIDGE:BREAK set) exploited as a zero-day: an unauthenticated attacker runs commands as root by injecting them into the username field of a failed login (HTTP RPC log routine concatenates the username into a shell command). Actor 'Chaya_006' hit honeypots from 5 Apr - weeks before public disclosure - likely reverse-engineering the 20 Feb patch. CISA KEV 23 Jun (due 26 Jun). Patch to EDS5000 2.2.0.0R1; remove serial-to-IP servers from internet exposure and segment OT.

PoC: Active exploitation (honeypots since 5 Apr; pre-disclosure)

Refs: thehackernews.com · securityweek.com · forescout.com

CVE-2026-12847 - GeoVision GV-I/O Box 4E DVRSearch UDP stack overflow (CVSS 10.0), unauth RCE

CRITICAL

VERIFIED

IoT

RCE

PreAuth

Talos

Cisco Talos (Philippe Laulheret) disclosed a CVSS-10 stack buffer overflow in DVRSearch, a UDP service running by default on the GeoVision GV-I/O Box 4E (port 10001). Any network-reachable attacker can send a crafted UDP message (an attacker-controlled gateway field overflows the buffer) for unauthenticated, no-interaction RCE. Version 2.09 affected; 2.12 unaffected. Trivially wormable if exposed - block DVRSearch UDP at the perimeter, segment IoT/OT VLANs, apply firmware.

Refs: vulnerability.circl.lu · talosintelligence.com · cve.threatint.eu

CVE-2026-55200 - libssh2 OOB heap write in ssh2_transport_read() (CVSS 9.2), client RCE, public PoC

CRITICAL

VERIFIED

Library

RCE

SupplyChain

An integer overflow in ssh2_transport_read() (packet_length never bounds-checked; 32-bit add wraps so a tiny buffer is allocated then overflowed) gives an out-of-bounds heap write reachable pre-auth during transport negotiation. A malicious/compromised SSH server (or MITM) can corrupt a connecting client's heap - no creds, no interaction - affecting every libssh2 <= 1.11.1 (curl, git tooling, automation agents, network mgmt). Public PoCs are out. Hardest part of cleanup is finding bundled/static copies; inventory and rebuild downstream software.

PoC: Public - PoC repos (bikini/exploitarium, 0xBlackash) - github.com

Refs: thehackernews.com · cybersecuritynews.com · securityonline.info

CVE-2026-42530 & CVE-2026-42055 - NGINX critical RCE (HTTP/3 UAF + HTTP/2 HPACK overflow, CVSS 9.2)

CRITICAL

VERIFIED

WebServer

RCE

PreAuth

F5 shipped out-of-band fixes for two unauthenticated, remotely triggerable NGINX flaws. CVE-2026-42530 is an HTTP/3 QUIC use-after-free (lifetime mismatch leaves a freed stream pointer treated as valid) - worker crash, RCE if ASLR is bypassed. CVE-2026-42055 lets oversized HPACK data write past its buffer (heap overflow) when proxying HTTP/2 upstream. Patch to NGINX OSS 1.31.2 / 1.30.3 or NGINX Plus R37 P2.1 / R36 P6; if delayed, disable HTTP/3 and apply HTTP/2 config mitigations.

Refs: thehackernews.com · securityweek.com · bleepingcomputer.com

CVE-2026-56141 - JetBrains Hub account takeover via predictable restore codes (CVSS 9.8)

CRITICAL

VERIFIED

IAM

ATO

WeakRNG

JetBrains Hub - the identity/SSO service fronting TeamCity, YouTrack and Space - generates predictable account-restore codes (weak RNG), letting an attacker guess/brute-force a victim's code and seize the account with no credentials (low complexity, no privileges, no interaction). A single ATO can cascade into CI/CD and source-adjacent systems. Fixed in 2026.1.13757+ (and equivalent 2024-2025 builds). Patch now, invalidate outstanding restore codes, force re-auth, enforce MFA.

Refs: vulnerability.circl.lu · jetbrains.com · cvedetails.com

Keycloak CVE-2026-4282 + CVE-2026-9802 - auth-code/refresh-token weaknesses (part of 16-CVE 26.6.3 release)

CRITICAL

VERIFIED

IAM

PrivEsc

TokenReplay

Keycloak shipped 26.6.3 patching 16 CVEs. CVE-2026-4282 is privilege escalation via forged authorization codes (SingleUseObjectProvider isolation flaw; addressed in 26.5.7). CVE-2026-9802 lets an attacker who captured a refresh token replay it even after revocation, because a server/cluster restart resets revocation timing (revokeRefreshToken=true + persistent sessions) - breaking IR revocation assumptions. NOTE: an earlier single-source vault capture framed 4282 as 'unauthenticated admin-token forgery'; vendor advisories describe forged auth codes - corrected here. Upgrade to 26.6.3, force global logout, restrict admin-console exposure.

Refs: keycloak.org · blog.idptrust.com · cvefeed.io

CVE-2026-20245 - Cisco Catalyst SD-WAN Manager command injection, exploited 0-day (admin->root)

HIGH

VERIFIED

Network

PrivEsc

ZeroDay

Mandiant

Mandiant reports CVE-2026-20245 (command injection via an insufficiently validated file-upload feature in SD-WAN Manager/vManage) exploited as a zero-day from late 2025 - at least two months before disclosure. The actor uploaded evil_tenant.csv, backed up /etc/passwd and /etc/shadow, then created a rogue root account 'troot', and used anti-forensics (selective config delete/restore, log wiping). SD-WAN root yields broad traffic visibility and lateral movement. Patch, hunt for 'troot'/unexpected accounts and config-restore gaps, and move logging off-box.

PoC: Active exploitation (months pre-disclosure)

Refs: cloud.google.com · bleepingcomputer.com · thehackernews.com

CVE-2026-20230 - Cisco Unified CM SSRF, exploited (CVSS 8.6); CISA 3-day deadline

HIGH

VERIFIED

Telephony

SSRF

Exploited

KEV

Unauthenticated SSRF in Cisco Unified Communications Manager / SME (CVSS 8.6, requires WebDialer enabled) lets a remote attacker write files to the underlying OS that can be staged to elevate to root. Defused observed in-the-wild attacks from ~21-22 Jun using file:// payloads. CISA added it to KEV under BOD 26-04 with a 28 Jun deadline. Cisco patched on 3 Jun - apply the fix, restrict CUCM management interfaces, and monitor for anomalous file creation/outbound from CUCM hosts.

PoC: Active exploitation in the wild (file:// payloads)

Refs: bleepingcomputer.com · securityweek.com · cisa.gov

GLOBAL - OTHER NOTABLE VULNERABILITIES

High severity

CVE-2026-8461 'PixelSmash' - FFmpeg MagicYUV decoder heap OOB write (CVSS 8.8), Jellyfin RCE

HIGH

VERIFIED

Media

RCE

SupplyChain

JFrog's 'PixelSmash' (CVE-2026-8461) is a one-row heap overflow in FFmpeg's MagicYUV decoder (mismatch between frame-allocator and decoder chroma-plane height math). A single crafted AVI/MKV/MOV reaching libavcodec crashes Kodi, mpv, Jellyfin, Emby, Nextcloud, Immich, PhotoPrism and OBS; full RCE was demonstrated against Jellyfin 10.11.9 via its automatic library-scan/ffprobe pipeline (hijacking AVBuffer.free). Fixed in FFmpeg 8.1.2 (17 Jun). Patch FFmpeg and downstream apps; disable auto-transcode/thumbnailing of untrusted media.

PoC: Public - MagicYUV OOB-write PoC (published 24 Jun)

Refs: jfrog.com · bleepingcomputer.com · securityweek.com

CVE-2026-46331 / CVE-2026-43503 - Linux kernel in-memory setuid poisoning -> root (FIM-clean)

HIGH

VERIFIED

Linux

LPE

EvasionFIM

A cluster of Linux LPE bugs (CVE-2026-46331 and the related 'DirtyClone' CVE-2026-43503 - reportedly the 4th same-failure-mode bug in two months) escalate to root by poisoning the cached in-memory copy of /bin/su (or /usr/bin/su); the on-disk binary is untouched so AIDE/Tripwire/IMA stay clean. A public PoC (packet_edit_meme by Massimiliano Oldani, 'pedit COW') frames CVE-2026-46331 as residing in the net/sched act_pedit action (CVSS 7.8) - this diverges from the cached-su description; confirm against NVD/kernel advisory whether it is description drift or a CVE-id collision. Do not rely on disk FIM - use eBPF/runtime setuid-exec telemetry; patch kernels promptly.

PoC: Public - 'pedit COW' / packet_edit_meme PoC (0xBlackash) - github.com

Refs: x.com/TheHackersNews · x.com/TheHackersNews · x.com/DailyDarkWeb

CVE-2025-20701 - Airoha Bluetooth SoC eavesdrop/RAM-flash R/W (Beats + Sony/Bose/JBL, CVSS 8.8)

HIGH

VERIFIED

Bluetooth

Hardware

Eavesdrop

A missing-authentication weakness in the Airoha Bluetooth SoC (used across many true-wireless earbuds) lets an in-range attacker pair without consent and listen via the mic while buds seek pairing. Follow-up reporting clarifies the flaw class is broader: an attacker can read/write the headphone's RAM and flash and abuse the trust the buds have with their paired phone (toward firmware tampering/pivoting). Apple fixed Beats Studio Buds in firmware 1B211; Sony/Bose/JBL/Marshall/Jabra and others have shipped fixes - apply latest firmware and pair only in trusted environments.

Refs: thehackernews.com · bleepingcomputer.com · scworld.com

CVE-2026-45504 - Microsoft Exchange Server SSRF -> arbitrary file read (CVSS 8.8), public PoC

HIGH

UNVERIFIED

Exchange

SSRF

FileRead

An SSRF in Microsoft Exchange Server (Exchange 2016 CU23 referenced) lets an authorised attacker coerce the server into requests that yield arbitrary file read from the host - a primitive that frequently chains into NTLM relay, credential theft and AD pivoting on this perennial top target. Public PoC code and a hawktrace writeup are available, shortening the window to mass scanning. Map CVE-2026-45504 to your build via MSRC and patch; restrict OWA/admin endpoints and hunt anomalous internal requests from Exchange. Two social-media sources only - unverified.

PoC: Public - PoC + writeup (hawktrace) - github.com

Refs: x.com/DarkWebInformer · x.com/ptdbugs

CVE-2026-20251 - Splunk Secure Gateway jsonpickle deserialization RCE (CVSS 8.8), PoC referenced

HIGH

UNVERIFIED

Splunk

Deserialization

RCE

A jsonpickle deserialization flaw in Splunk Secure Gateway (the app powering Splunk mobile / Connected Experiences) lets crafted serialized objects decode into arbitrary Python objects -> RCE on the Splunk instance. Published 26 Jun; a PoC was referenced (github.com/reactivezero). Inventory Splunk deployments with Secure Gateway enabled, apply the fixed version once advised, restrict access to Secure Gateway endpoints, and watch for anomalous child processes of the Splunk process. Single-source - unverified.

PoC: Public - PoC referenced (reactivezero)

Refs: x.com/DarkWebInformer

CVE-2026-11999 - wolfSSL OpenSSL-compat X.509 trust-chain bypass (path-depth exhaustion)

HIGH

UNVERIFIED

TLS

AuthBypass

Crypto

A flaw in wolfSSL's OpenSSL-compatibility certificate verifier (wolfSSL_X509_verify_cert) allows an X.509 trust-chain bypass via path-depth exhaustion, letting an untrusted certificate validate (TLS auth bypass / MITM). Affects only builds using the OpenSSL-compat verification path. Audit products embedding wolfSSL with opensslextra-style compat enabled, update to a fixed release, and enforce explicit chain-depth/pathlen limits. Single-source - unverified.

Refs: x.com/CVEnew

CVE-2026-3227 - TP-Link router flaw, public PoC released (SOHO/edge)

HIGH

UNVERIFIED

Router

SOHO

PoC

A public GitHub PoC was released for a network-reachable flaw in affected TP-Link router firmware - lowering the bar for mass exploitation of internet-exposed SOHO routers (botnet recruitment, pivoting). Identify in-scope models, apply latest firmware, disable WAN-side management, rotate credentials and watch for the PoC's exploitation patterns. Single-source - unverified.

PoC: Public - PoC (do4choo) - github.com

Refs: x.com/DarkWebInformer

AnyDesk 'AnyPwn' - claimed pre-auth 'Oclick' heap-overflow RCE (PoC teased)

HIGH

UNVERIFIED

RemoteAccess

PreAuth

Claim

A researcher teased 'AnyPwn', a claimed pre-authentication heap-buffer-overflow RCE in AnyDesk reached during connection establishment (an 'Oclick' trigger), with screenshots showing a listener, heap-spray and trigger packet. If valid, an attacker able to reach an AnyDesk endpoint could execute code unauthenticated - high value given AnyDesk's broad deployment and frequent abuse. No CVE confirmed; PoC/patch promised post-disclosure. Treat as a pending high-risk disclosure: inventory AnyDesk exposure, restrict to allowlisted peers, watch for the advisory. Single-source - unverified.

Refs: x.com/v12sec

GLOBAL - SOFTWARE SUPPLY CHAIN

Worms & OAuth

Shai-Hulud / Miasma 'Phantom Gyp' worm - 23 poisoned LeoPlatform npm versions (leo-sdk, leo-logger)

CRITICAL

VERIFIED

npm

Worm

CredTheft

On 24 Jun an attacker used a stolen npm token (maintainer 'czirker') to publish 23 poisoned versions across the LeoPlatform/RStreams ecosystem (leo-sdk, leo-aws, leo-cli, leo-logger and ~20 siblings, ~52,640 monthly downloads) in a ~6-second burst. The 'Phantom Gyp' technique hides execution in a binding.gyp file (node-gyp runs it - no package.json lifecycle script), unpacking a 5MB worm that steals cloud creds, password managers, Anthropic API keys and masked GitHub Actions secrets, then propagates. The actor also repointed leo-sdk's 'latest' dist-tag to the poisoned 6.0.19 line. Pin exact versions, rotate npm/CI/cloud secrets, audit binding.gyp in installed deps.

Refs: research.ifrog.com · socket.dev · endorlabs.com

JetBrains Marketplace - 15 malicious AI plugins stole API keys from ~70k installs (C2 live post-removal)

HIGH

VERIFIED

IDE

SupplyChain

CredTheft

JetBrains removed 15 Marketplace plugins, blocked 7 publisher accounts and disabled the plugins in installed IDEs after finding they steal AI-provider API keys (DeepSeek/OpenAI/SiliconFlow). The plugins offered real AI features while exfiltrating validated keys as plaintext JSON over unencrypted HTTP to hardcoded C2 39.107.60[.]51. Activity ran since ~late Oct 2025 across ~70,000 installs, with new plugins as recent as 10 Jun; the C2 was still live on 19 Jun (three days after removal) - so exposed keys must be treated as leaked. Audit installed plugins, revoke/rotate AI API keys, block the C2.

PoC: C2 39.107.60[.]51 confirmed live 19 Jun (post-removal)

Refs: blog.jetbrains.com · thehackernews.com · stepsecurity.io

Polymarket - frontend supply-chain attack drains ~\$3M via injected JavaScript

HIGH

VERIFIED

Web

Magecart

DeFi

A compromised third-party frontend vendor let attackers inject malicious JavaScript into Polymarket's website, tricking users into approving fraudulent transactions (~\$3M / ~\$3.1M in pUSD drained from <15 accounts; funds swapped to ~1,893 ETH and bridged Polygon->Ethereum). Backend/servers were unaffected; Polymarket removed the dependency and will fully reimburse. Classic Magecart-style web supply-chain pattern - enforce Subresource Integrity (SRI) + strict CSP, pin third-party scripts, and alert on new external script origins on production pages.

Refs: bleepingcomputer.com · securityweek.com · thenextweb.com

LastPass confirms Salesforce data exposed via Klue OAuth-token supply-chain breach ('Icarus')

HIGH

VERIFIED

SaaS

OAuth

Breach

The 'Icarus' extortion group used a compromised legacy credential at market-intelligence vendor Klue to mint OAuth tokens and exfiltrate connected customers' Salesforce CRM data in bulk via automated scripts. LastPass (and BeyondTrust) confirmed exposure of customer names, emails, phone/addresses and support-case details; LastPass says vaults/products/core infra were unaffected and tokens are revoked. Continuation of the SaaS-integration OAuth-token theft wave (Salesloft/Drift lineage). Inventory connected OAuth apps to Salesforce, revoke over-permissioned tokens, enable API anomaly monitoring.

Refs: bleepingcomputer.com · helpnetsecurity.com · securityweek.com

GLOBAL - PUBLIC PoCs & OFFENSIVE TOOL RELEASES

PoC / exploit code & tools

libssh2 CVE-2026-55200 - public client-RCE PoCs

WATCH

VERIFIED

PoC

RCE

SSH

Multiple PoCs (bikini/exploitarium, 0xBlackash) demonstrate triggering the libssh2 OOB heap write from a malicious SSH server against connecting clients - no creds/no interaction. Opportunistic exploitation of clients lured to hostile SSH endpoints becomes more likely; prioritise dependency inventory of static/bundled libssh2.

Refs: github.com · cybersecuritynews.com · github.com

Ghost CMS CVE-2026-26980 - public unauth SQLi PoCs / lab

WATCH

VERIFIED

PoC

SQLi

CMS

Full exploit frameworks and a lab environment for the Ghost Content-API blind SQLi are public (vognik, dinosn), alongside an active mass-exploitation campaign hijacking 700+ sites for ClickFix lures. Patch Ghost to 6.19.1 and rotate Admin API keys/session secrets.

Refs: github.com · github.com · bleepingcomputer.com

FFmpeg PixelSmash CVE-2026-8461 - public MagicYUV OOB-write PoC

WATCH

VERIFIED

PoC

RCE

Media

A working PoC (published 24 Jun) for the MagicYUV heap OOB write raises exploitation risk for any service auto-decoding untrusted media. Patch FFmpeg to 8.1.2 and block/transcode untrusted MagicYUV input in isolated workers.

Refs: jfrog.com · securityweek.com

Joomla SP Page Builder CVE-2026-48908 - public unauth-RCE PoC

WATCH

VERIFIED

PoC

RCE

CMS

A self-cleaning, token-guarded unauth-RCE PoC (papageo75) targets asset.uploadCustomIcon on SP Page Builder <= 6.6.1; live exploitation is already in the wild. Update to 6.6.2 and hunt for @secure.local Super User accounts.

Refs: github.com · censys.com

Joomla JCE CVE-2026-48907 - public GitHub scanner / fingerprinter

WATCH

VERIFIED

PoC

Scanner

CMS

A public repo (gh1mau/masta-cve-2026-48907) advertises Joomla + JCE fingerprinting and version checks for the actively-exploited CVE-2026-48907 - lowering the bar for mass scanning of internet-facing Joomla sites. Patch JCE to 2.9.99.5+.

Refs: github.com · thehackernews.com

MS Exchange CVE-2026-45504 - public SSRF file-read PoC (hawktrace)

WATCH

UNVERIFIED

PoC

SSRF

Exchange

Public PoC + writeup for an Exchange SSRF -> arbitrary file read. On-prem Exchange remains a high-value target (relay/AD pivot); map to your build and patch. Single-source disclosure - unverified.

Refs: github.com · x.com/DarkWebInformer

Ivanti Sentry CVE-2026-10520/10523 - public PoC (gagaltotal)

WATCH

UNVERIFIED

PoC

Edge

Ivanti

Public exploit code for the Ivanti Sentry chain (CVE-2026-10520 -> 10523). Ivanti edge products have a strong recent record of mass in-the-wild exploitation, so public PoC against Sentry warrants priority patching and segmentation of admin interfaces. Single-source - unverified.

Refs: github.com · x.com/ptdbugs

CVE-2026-55607 - Claude Code git-worktree sandbox escape (writeup + advisory)

WATCH

UNVERIFIED

PoC

AIAgent

SandboxEscape

GHS-7835-87q9-rgvv (CVSS 7.7, patched in Claude Code 2.1.163): a 3-bug chain (.git accepted as worktree name; worktree creation follows symlinks; git-config indirection + write-to-\$HOME) lets prompt-injection-driven tooling escape the sandbox to unsandboxed host code execution - reportedly even in read-only + full-sandbox mode. Treat agent 'sandbox/'read-only' as defence-in-depth, isolate at OS/container/VM layer; hunt for worktrees named .git and unexpected \$HOME/global git-config writes. Single-source writeup - unverified.

Refs: github.com · x.com/v_metnew

PCredz - network-traffic credential capture (red-team tool)

INFO

UNVERIFIED

Tool

CredCapture

RedTeam

PCredz extracts NTLM hashes, Kerberos, plaintext creds, SNMP strings and basic-auth from live traffic or PCAPs - paired with Responder/NTLM relay for credential-less lateral movement. Defenders: enforce SMB signing, disable NTLMv1, encrypt internal protocols, and alert on promiscuous-mode/responder activity. Single-source mention - unverified.

Refs: x.com/cottatatal

PowerShell 'Mayhem Edition' - destructive LOLBIN techniques (awareness)

INFO

UNVERIFIED

Tool

LOLBIN

Windows

A reminder that unrestricted PowerShell enables binary-less destruction (remove Windows licences, disable USB/NICs, corrupt the MBR so the host won't boot). Enforce Constrained Language Mode, ScriptBlock/Module logging + transcription, AMSI and WDAC/AppLocker; alert on raw disk writes, slmgr tampering and bootsector access from PowerShell. Single-source - unverified.

Refs: x.com/co11ateral

Defensive releases - YARA-X 1.18/1.19 & RBACMap (M365 RBAC navigator)

INFO

UNVERIFIED

Tool

Defense

Blue

Blue-team tooling this week: YARA-X 1.18.0/1.19.0 (the Rust YARA rewrite) shipped improvements/bugfixes - update detection pipelines and review rule compatibility. RBACMap (rbacmap.com) interactively maps 300+ M365/Entra admin roles to find least-privilege roles and visualise role sprawl. Single-source items - unverified.

Refs: isc.sans.edu · x.com/0x534c

GLOBAL - MALWARE & CAMPAIGNS

StegoAd - Microsoft removes 119 malicious Edge extensions hiding payloads in images/fonts

HIGH

VERIFIED

BrowserExt

Steganography

CredTheft

Microsoft removed 119 Edge extensions (campaign 'StegoAd', active since ~2021) that hid malicious code via steganography in PNG/WebP/WOFF2 images and fonts. Published via 90+ developer accounts sharing infrastructure/codebase, they posed as ad blockers, VPNs, translators and downloaders (THN reports up to ~2.6M installs), delivered genuine functionality, then dropped payloads 3-5 days post-install to steal credentials, hijack sessions and run ad fraud. Audit installed Edge extensions, remove untrusted ad-blocker/VPN/translator/downloader add-ons, rotate affected creds, and enforce extension allow-listing.

Refs: news.risky.biz · thehackernews.com · hendryadrian.com

STOCKSTAY - Turla (Russia) new .NET backdoor vs Ukraine gov/military (Kazuar overlap)

HIGH

VERIFIED

APT

Russia

Espionage

Google/Mandiant attribute a new multi-component .NET backdoor, STOCKSTAY (WinForms; WebSocket C2 via websocket-sharp), to Turla, deployed against Ukrainian government/military and entities interested in Italian foreign policy (early versions also hit Italy, Netherlands, Poland, Germany). It shares significant code/overlap with Kazuar and was seen alongside other Turla tooling (WILDDAY, DIAMONDBACK). Delivery uses academic/diplomatic-themed phishing, .rdp/MSI files and WinRAR CVE-2025-8088 lures. Block inbound .rdp/.msi, patch WinRAR, and hunt Kazuar-overlapping indicators.

Refs: cloud.google.com · thehackernews.com · therecord.media

BumbleBee -> AdaptixC2 + RustDesk + reverse-SSH -> Akira ransomware (DFIR Report)

HIGH

VERIFIED

Ransomware

IntrusionChain

Akira

The DFIR Report details an intrusion using BumbleBee (loader) -> AdaptixC2 (open-source C2) + RustDesk (dual-use remote desktop) + a reverse SSH tunnel for C2, culminating in Akira ransomware deployed ~44 hours after initial compromise, starting with the backup server. Detection ideas: alert on unsanctioned RustDesk, hunt reverse SSH tunnels (ssh -R) from non-admin hosts, and watch for BumbleBee/AdaptixC2 beacon patterns - prioritise backup-server isolation and immutable backups.

Refs: x.com/TheDFIRReport · x.com/TheDFIRReport · thedfirreport.com

FBI/CISA - Russian phishers now steal Signal backup recovery keys

HIGH

VERIFIED

Phishing

Russia

AccountTakeover

FBI/CISA warn a Russia-linked phishing campaign now steals Signal Backup Recovery Keys - with the key, attackers restore old backups, read message history and take over the account, building on prior 'linked device' QR-code lures. A related SSU+FBI-reported strand uses fake support SMS as the entry point against Ukrainian officials/military/activists. Treat any request to share a Signal recovery/backup key as hostile, regenerate keys if exposure is suspected, review linked devices, and brief high-risk users on QR/recovery-key and 'support SMS' lures.

Refs: bleepingcomputer.com · x.com/TheHackersNews · therecord.media

Operation Endgame - Europol disrupts Amadey & StealC (326 servers, 142 domains, EUR41M frozen)

MEDIUM

VERIFIED

Takedown

Infostealer

Europol

Europol-led Operation Endgame dismantled ~326 servers and seized ~142 domains behind the Amadey loader and StealC infostealer (also SocGhosh), froze ~EUR41M (~\$46.5M) in crypto and recovered ~27M stolen credentials. Amadey gains initial access; StealC harvests passwords/data - together linked to 140k+ infected machines in early May. Takedowns are often temporary: refresh blocklists from the official IOC release, hunt historically for Amadey/StealC, rotate potentially-harvested credentials, and watch for migration to successor stealers (Lumma/Vidar).

Refs: europol.europa.eu · bleepingcomputer.com · infosecurity-magazine.com

AryStinger - proxy botnet conscripts 4,300+ legacy D-Link/SOHO routers

MEDIUM

VERIFIED

Botnet

Router

ORB

AryStinger compromises end-of-life/legacy SOHO routers - notably D-Link - and uses them for reconnaissance and proxying (scanning targets, tunnelling traffic, running commands remotely) rather than DDoS, blending activity into residential/SMB IP space. ~4,300+ infected routers reported. Consistent with the ORB (Operational Relay Box) trend on consumer edge devices. Retire/isolate EoL routers, disable WAN-side admin, change default creds, and hunt for unexpected outbound tunnels/scanning from edge devices.

Refs: bleepingcomputer.com · malwarebytes.com · x.com/TheHackersNews

macOS 'Gaslight' - DPRK-aligned Rust backdoor uses prompt injection to derail AI malware triage

MEDIUM

VERIFIED

macOS

AntiAI

PromptInjection

SentinelLABS analysed macOS.Gaslight, a single persistent Rust implant (assessed DPRK-aligned) that embeds a ~3.5KB prompt-injection payload of 38 fabricated 'system' messages (token-expiry, memory/disk errors, fake injection flaws) to push LLM-assisted triage agents into aborting analysis. It also bundles a credential/session stealer, interactive shell and a self-staged Python collector behind a Telegram Bot API C2 (AES-GCM over cert-pinned TLS). The injection did not defeat production AI analysis platforms in testing, but signals malware targeting the analyst's AI tooling - treat LLM output on untrusted binaries as advisory, and flag macOS processes using Telegram Bot API endpoints.

Refs: sentinelone.com · thehackernews.com · infosecurity-magazine.com

macOS ClickFix variant - silent background DMG mount drops infostealer / crypto-wallet theft

MEDIUM

UNVERIFIED

macOS

ClickFix

Infostealer

Unit 42 reports a macOS ClickFix variant where, after the victim pastes a command (the ClickFix 'fix-it' lure), the chain invisibly mounts a DMG in the background (hdiutil attach -nobrowse style) and runs an infostealer that drains crypto wallets alongside browser/credential theft - silent mounting avoids Finder/Installer UI cues. User awareness: never paste website commands into Terminal. Hunt unexpected background DMG mounts followed by execution from /Volumes, and non-browser access to wallet/credential stores. Single-source - unverified.

Refs: x.com/Unit42_Intel

WhatsApp VBScript campaign installs ManageEngine Endpoint Central (RMM) for remote access

MEDIUM

UNVERIFIED

RMMAbuse

VBScript

RAT

A campaign spreads via WhatsApp Desktop/Web 'document from a trusted contact' lures: a VBScript masquerading as a document silently installs the legitimate ManageEngine Endpoint Central RMM agent for remote access/persistence - living-off-trusted-software to blend in. Block/inspect WhatsApp file delivery on managed endpoints, allowlist sanctioned RMM tools and alert on unexpected Endpoint Central installs, and hunt wscript/cscript executing .vbs from temp/download paths. Single-source - unverified.

Refs: x.com/TheHackersNews

GLOBAL - NOTABLE BREACHES**FortiBleed - mass Fortinet firewall/VPN credential-compromise campaign (still active)**

HIGH

VERIFIED

CredTheft

Fortinet

Edge

SOCradar disclosed 'FortiBleed', an active campaign around compromised Fortinet credentials across 194 countries (US #2 most-targeted; victims include banks, telecoms, government). Figures vary by lens - ~30k+ confirmed credentials, BleepingComputer counts VPN creds for ~73,932 firewall URLs, and ~320k devices reportedly targeted/scanned. A follow-on 'FortigateSniffer' Golang tool was claimed to have harvested 110M creds from 430k FortiGates since Feb (incl. a NATO contractor) - unconfirmed. Check Fortinet admin/VPN logs for anomalous logins, rotate admin/VPN credentials, enforce MFA, and restrict management interfaces.

Refs: bleepingcomputer.com · x.com/socradar · x.com/IntCyberDigest

Jaguar Land Rover 2025 attack re-attributed to Russian hackers (NYT) - ~\$2.5B, costliest UK breach**HIGH****VERIFIED****Breach****Russia****Manufacturing**

A New York Times investigation attributes the Aug 2025 JLR attack - which halted production for ~6 weeks and is described as the costliest UK cyberattack (est. \$2.5B / GBP1.9B, 5,000+ supply-chain orgs affected, a measurable GDP dent) - to Russian hackers, overturning the group that originally claimed credit. Microsoft tracked the actor and alerted JLR; FBI, NCA, NCSC, Mandiant and Palo Alto contributed. Reinforces that claim-of-credit is not attribution, and the outsized financial impact of disruptive intrusions on manufacturing/OT-adjacent IT.

Refs: techcrunch.com · thenextweb.com · scworld.com

Xsolis (healthtech) - phishing-led breach exposes ~1.4M individuals' data**MEDIUM****UNVERIFIED****Breach****Healthcare****Phishing**

Healthcare-technology firm Xsolis disclosed that a phishing attack gave attackers network access and exposed sensitive data for ~1.4 million individuals. PHI exposure carries elevated harm (identity/medical-insurance fraud) and HIPAA notification obligations. Customers/partners should request scope and affected-data detail; reinforce phishing-resistant MFA, email filtering and least-privilege for network-access accounts. Single-source - unverified.

Refs: bleepingcomputer.com

INDICATORS OF COMPROMISE (IOCs) TO ADD

Blocklist / SIEM

Indicator	Type	Context	Reference
CVE-2026-34908 / 34909 / 34910	CVE	Ubiquiti UniFi OS unauth root RCE chain (CVSS 10) - exploited (Mirai/Gafgyt); fix 5.0.8	cisa.gov
CVE-2026-48907	CVE	Joomla JCE improper access control -> PHP RCE (CVSS 10) - exploited; fix 2.9.99.5	thehackernews.com
CVE-2026-48908	CVE	SP Page Builder (Joomla) unauth upload -> RCE (CVSS 10) - exploited; fix 6.6.2	censys.com
CVE-2026-26980	CVE	Ghost CMS unauth blind SQLi (CVSS 9.4) - exploited; fix 6.19.1	bleepingcomputer.com
CVE-2025-67038	CVE	Lantronix EDS5000 BRIDGE:BREAK root cmd-injection (CVSS 9.8) - exploited 0-day; fix 2.2.0.0R1	thehackernews.com
CVE-2026-12847	CVE	GeoVision GV-I/O Box 4E DVRSearch UDP overflow (CVSS 10) - unauth RCE; v2.12 fixed	vulnerability.circl.lu
CVE-2026-55200	CVE	libssh2 OOB heap write (CVSS 9.2) - client RCE, public PoC; <=1.11.1	thehackernews.com
CVE-2026-42530 / 42055	CVE	NGINX HTTP/3 UAF + HTTP/2 HPACK overflow (CVSS 9.2); fix 1.31.2 / 1.30.3	bleepingcomputer.com
CVE-2026-56141	CVE	JetBrains Hub ATO via predictable restore codes (CVSS 9.8); fix 2026.1.13757+	vulnerability.circl.lu
CVE-2026-20245	CVE	Cisco Catalyst SD-WAN Manager cmd injection - exploited 0-day (rogue 'troot')	cloud.google.com
CVE-2026-20230	CVE	Cisco Unified CM SSRF (CVSS 8.6) - exploited; CISA KEV (WebDialer)	cisa.gov
CVE-2026-8461	CVE	FFmpeg MagicYUV heap OOB write 'PixelSmash' (CVSS 8.8); fix 8.1.2	ifrog.com
39.107.60[.]51	IPv4 (C2)	JetBrains malicious-plugin C2 (AI API-key theft) - live post-removal	thehackernews.com
easy-day-js (npm)	Malicious package	DPRK Mastra supply chain - dayjs typosquat; postinstall dropper	microsoft.com
@mastra/* (141 poisoned versions)	Malicious packages	DPRK Sapphire Sleet npm compromise; rotate dev/CI secrets	bleepingcomputer.com

Indicator	Type	Context	Reference
leo-sdk / leo-logger / leo-aws (poisoned)	Malicious packages	Shai-Hulud 'Phantom Gyp' npm worm (binding.gyp exec); pin & rotate	research.ifrog.com
Super User @secure.local (Joomla)	Account artifact	SP Page Builder CVE-2026-48908 post-exploit rogue admin	censys.com
github[.]com/papageo75/CVE-2026-48908-PoC	URL (PoC)	Joomla SP Page Builder unauth RCE exploit code	github.com
github[.]com/bikini/exploitarium (libssh2)	URL (PoC)	libssh2 CVE-2026-55200 client-RCE PoC	github.com
Telegram Bot API C2 (macOS process)	Behaviour/C2	macOS.Gaslight Rust implant C2 + AI-triage prompt injection	sentinelone.com

Defanged indicators - re-fang before importing. Verify against your environment before blocking.

TRENDS & EMERGING THREATS TO WATCH

Forward look

HIGH

CISA-KEV max-severity flaws on internet-facing appliances & CMS

Why it matters: UniFi OS (10.0), two Joomla extensions (10.0), GeoVision (10.0), Lantronix OT and Cisco CM/SD-WAN all landed as exploited this week, several with automated attacks and botnet recruitment. Edge/appliance and popular CMS plugins remain the fastest route from disclosure to compromise.

Watch for: unpatched UniFi/Joomla/Cisco/Lantronix/GeoVision; CISA KEV due-dates; webshells and rogue admin accounts (e.g. Joomla @secure.local Super Users, Cisco 'trout'); botnet scanning from edge devices.

HIGH

Public PoCs compress disclosure-to-exploitation - especially for CMS & bundled libraries

Why it matters: PoCs/scanners dropped for Ghost CMS, both Joomla flaws, libssh2, FFmpeg PixelSmash, Exchange SSRF and Ivanti Sentry within days; libssh2/FFmpeg/NGINX are bundled in countless products, so static/transitive copies are the cleanup problem.

Watch for: mass scanning right after PoC publication; software bundling vulnerable libssh2/FFmpeg/NGINX; internet-exposed Ghost/Joomla/Exchange; new GitHub 'CVE' repos framed as 0-days.

HIGH

DPRK & supply-chain worms targeting developer / AI ecosystems

Why it matters: DPRK's Sapphire Sleet poisoned 141 @mastra npm packages and the Shai-Hulud/Miasma 'Phantom Gyp' worm hit LeoPlatform npm - both steal CI/cloud/AI keys at install via hidden hooks (postinstall, binding.gyp). Malicious JetBrains AI plugins extend the theme into IDEs.

Watch for: dependency installs that execute via postinstall or binding.gyp; new maintainer-token publishes; npm/PyPI/IDE-plugin installs in the last 2 weeks; exfil of Anthropic/OpenAI/cloud keys from build agents.

MED

Malware turning on the defender's AI tooling

Why it matters: macOS.Gaslight embeds 38 fake 'system' messages to make LLM-assisted triage abort, and a 'clean' GitHub-repo technique tricks AI coding agents into running malware - attackers now target the analysis/automation layer, not just sandboxes.

Watch for: prompt-injection strings/fake errors embedded in binaries and repos; AI agents acting on untrusted repo/inbound content without human-in-the-loop; over-trust in LLM verdicts on untrusted samples.

MED

Web & SaaS supply-chain injection (frontend + OAuth tokens)

Why it matters: Polymarket lost ~\$3M to an injected frontend script via a compromised vendor, while the Klue OAuth-token theft kept claiming Salesforce tenants (LastPass, BeyondTrust). Trusted third-party JavaScript and integration tokens are high-leverage, low-visibility access.

Watch for: new/changed external script origins on production pages (use SRI+CSP); bulk record exports via connected-app OAuth tokens; over-permissioned/unused Salesforce integrations.

MED

Russia-nexus messaging-account & espionage operations

Why it matters: Turla's new STOCKSTAY .NET backdoor hit Ukraine gov/military, FBI/CISA warned of Signal backup-recovery-key phishing, and the JLR attack was re-attributed to Russian actors - persistent, high-impact state-aligned activity spanning espionage and disruption.

Watch for: Signal recovery-key / 'support SMS' lures against high-risk users; .rdp/MSI/WinRAR (CVE-2025-8088) phishing; Kazuar-overlapping indicators; unusual linked devices on messaging apps.

PRIORITY ACTIONS THIS WEEK

Area	Action
Patch now	UniFi OS -> 5.0.8 (CVE-2026-34908/09/10); Joomla JCE -> 2.9.99.5 (CVE-2026-48907) & SP Page Builder -> 6.6.2 (CVE-2026-48908); Ghost -> 6.19.1 (CVE-2026-26980); Lantronix EDS5000 -> 2.2.0.0R1 (CVE-2025-67038); GeoVision GV-I/O -> v2.12 (CVE-2026-12847); Cisco Unified CM (CVE-2026-20230) & Catalyst SD-WAN (CVE-2026-20245); libssh2 (CVE-2026-55200) & bundled copies; NGINX -> 1.31.2/1.30.3; JetBrains Hub -> 2026.1.13757+; Keycloak -> 26.6.3; FFmpeg -> 8.1.2; Beats/Airoha firmware.
Block IOCs	Add the IOC-table indicators (CVE IDs, JetBrains C2 39.107.60[.J51, easy-day-js / @mastra / leo-* malicious packages, Joomla SP Page Builder PoC + @secure.local Super Users, libssh2 PoC repo, macOS.Gaslight Telegram-C2 behaviour) to firewall/EDR/SIEM blocklists and alert on the listed CVEs.
Assume compromise	Treat internet-exposed UniFi OS, Joomla (JCE/SP Page Builder), Ghost, Lantronix, Cisco CM/SD-WAN as potentially compromised - hunt for webshells, rogue admin/root accounts ('troot', @secure.local), config-restore gaps and exfil; rotate appliance secrets.
Supply chain	Pin + hash-verify dependencies; audit binding.gyp and postinstall hooks; rebuild npm installs from the last 2 weeks (@mastra, leo-*); rotate npm/CI/cloud and Anthropic/OpenAI API keys; audit JetBrains/IDE plugins and revoke keys; enforce SRI + strict CSP on web frontends.
Identity & SaaS	Inventory & least-privilege Salesforce connected-app OAuth tokens (Klue), enable API anomaly monitoring; patch JetBrains Hub and force re-auth/MFA; review device-code/OAuth grants.
AI tooling & agents	Treat LLM analysis of untrusted binaries/repos as advisory; require human-in-the-loop for AI coding agents on untrusted repos; isolate agents at OS/container/VM layer (cf. Claude Code CVE-2026-55607); hunt prompt-injection strings in samples.
People & comms	Brief high-risk users on Signal recovery-key / 'support SMS' lures and WhatsApp 'document' VBScript lures; warn against pasting website commands into Terminal (macOS ClickFix); review AU/APAC third-party data exposure (Tata supply chain).
Local / AU	Begin Essential Eight -> 'Essentials' transition planning (control mapping, audit/contract updates); submit ACSC consultation feedback by 12 Jul if applicable.